1

For security, we need all of the different types of countermeasures: prevention, detection, and response.

- ✓ ● True
- ○ False

Feedback

Based on your answer

This statement is TRUE. Without prevention, we could only react to attacks once they're already underway and doing damage. Without detection, prevention would have to be perfect, which is not possible, and we would not find out that the security is compromised. Without response, we could not stop an attack or recover from it.

2

Disclosure and disruption are examples of threats against integrity.

- ○ True
- ✓ ● False

Feedback

Based on your answer

The statement is FALSE, disclosure is a threat against confidentiality, disruption is a threat against availability.

3

To protect against eavesdropping or malicious interference when sending a message from Alice to Bob over an insecure channel, they can use a cryptosystem. For that, they need secret algorithms for encryption, decryption, as well as for creating and exchanging either symmetric or asymmetric secret keys. Then Alice can turn the plaintext message into a ciphertext to send over the network to Bob who can turn it back into plaintext.

- ○ True
- ✓ ● False

Feedback

Based on your answer

This statement is FALSE. The algorithms are not secret (and shouldn't be). While they can have symmetric (shared) secret keys, if they use asymmetric cryptography they each need a public and private key pair, not just secret keys.

4

As long as a chosen password is not an actual word (e.g., because it contains numbers or special characters), it is safe from an offline dictionary attack.

- ✓ ● False
- ○ True

Feedback

Based on your answer

No, if it's too short, it can easily be part of an enumeration of all possibilities (brute force).

If it's a word that has been changed into "leetspeak" (some characters changed to numbers and symbols in a systematic way), that password is easily enumerated by a computer and thus almost as easy to guess as the original word.

Also, if a password contains several plain words it can actually be more secure from guessing than a short password consisting only of random characters.

5

Authentication can be done by proving something you know (e.g. password), something you have (e.g. access card), something you are or do (e.g. biometrics), your location, or several of these factors together.

- ○ False
- ✓ ● True

Feedback

Based on your answer

You can authenticate identity by something you know (a secret, like a password), if you (the identity in question) are the only one who should know that secret. Group membership if the secret is shared within a group. It can be phished.

Analogously, you can authenticate with something you have, such as an access card, because only the person authorized should have the card. And the card can't be copied easily. However, it can be stolen.

You can also authenticate your identity with something you are (e.g. biometrics), since these should be unique to you and hard to copy.

If you prove your location, you can authenticate your location. However, this can also be used to strengthen the other attributes: e.g. you're unlikely to log into your bank from abroad, when you just logged in from home.

6

A door can be unlocked using a card reader. Alice shows the card to the reader. The reader *authenticates* the card, checks if the card's holder is *authorized* to enter the door according to the security policy, and if so access is granted and the door can be unlocked.

- ✓ ● True
- ○ False

Feedback

Based on your answer

Correct. The authentication step is required by the authorization step. The card reader cannot authenticate Alice, only the card. The policy, however, is likely phrased in terms of Alice.

7

Social engineering exploits human behavior to get to people's individual assets, such as their passwords or their money, but it doesn't work against whole organizations.

- ○ True
- ✓ ● False

Feedback

Based on your answer

This statement is FALSE. Social engineering is often the entry point to a system that can then allow attackers to exploit other vulnerabilities. We've also seen several examples in the course where the victim's assets (e.g. their work computer, their passwords) are used to compromise any other assets the victim is authorized to access.

8

Preventing injection requires keeping data separate from commands and queries.

- ✓ ● True
- ○ False

Feedback

Based on your answer

This statement is TRUE. If data input from users (attackers) can get interpreted as code (commands, queries), they can use the data input to inject malicious code and thus lead to unauthorized disclosure, modification, destruction of data or other threats to security.

9

A legitimate user cannot be an intruder, as they already have access to the system.

- ○ True
- ✓ ● False

Feedback

Based on your answer

Correct. A legitimate user can misuse their privileges. Such an intruder would be called a misfeasor.

10

A polymorphic virus is a virus capable of targeting multiple architectures and operating systems

- ○ True
- ✓ ● False

Feedback

General Feedback

No, a polymorfic virus is a virus that modifies its binary code at each infection, making difficult to identify a pattern

11

Worms usually propagate by exploiting bugs of remote systems and copying themselves on the remote host.

✓ ● True

○ False

Feedback

General Feedback

Yes, for example they could use a remote telnet that is protected via weak password.

12

A firewall enforces certain traffic flows.

✓ ● True

○ False

Feedback

Based on your answer

Correct. A firewall has rules which says how network packets may flow over the network (crossing the firewall).

13

The GDPR is a set of recommendations for data protection for data processing in the EU.

- ○ True
- ✓ ● False

Feedback

Based on your answer

The statement is FALSE. It's a regulation, not a recommendation, and thus binding. And it concerns data concerning people in all of the EU, no matter where the processing is done.

14

A Reflection Attack happens when the attacker causes damage to themself, by receiving too many packets in response to an attack they are performing.

- ○ True
- ✓ ● False

Feedback

General Feedback

No. In a reflection attack the adversary sends data to an host B, forging requests (e.g. spoofing IP of A) that makes B to send replies to A.

15

Guard pages can be used to detect buffer overflows by causing some buffer overflow to access illicit memory and trap into the kernel.

- ✓ ● True
- ○ False

Feedback

General Feedback

True, they are basically regions of non accessible memory placed between buffers. If a buffer is allocated below a guard page, a buffer overflow of the buffer will "usually" write into the non accessible page. This will cause an exception (i.e.. trap) that causes the activation of the kernel, which can suspend or kill the faulty program

16

A buffer overflow happens when a program reads more data than the capacity of a buffer, reading the memory after the buffer.

- ○ True
- ✓ ● False

Feedback

General Feedback

False, this is a buffer over read. A buffer overflow happens when the program writes more data than the capacity of the buffer.

17

Executable Address Space Protection consists of making the program memory non-readable in order to prevent reverse engineering of binary code.

- ◯ True
- ✓ ◉ False

Feedback

Based on answering correctly

False, it makes the executable memory non-writable so that a memory error (like a buffer overflow) cannot owerwrite the program code

18

A timing side channel can be used to modify the critical data of a progam.

- ◯ True
- ✓ ◉ False

Feedback

General Feedback

No, side channels can only be used to leak data (i.e. compromise confidentiality), not to modify data.